Context-Aware Vulnerability Prioritization for Critical-Infrastructure and Public-Sector Endpoint Fleets

Harshavardhan Malla Independent Researcher
Email: harshavardhanmalla75@gmail.com

***Abstract*: Exploit-likelihood prioritization, expressed through the Exploit Prediction Scoring System (EPSS) [1], and hygiene-augmented prioritization, which adds host patch posture and exposure signals to EPSS, both rank a (host, CVE) pair by how likely the CVE is to be exploited and how poorly the host is maintained. Neither assigns weight to how much the organization would lose if a given host were compromised. Critical-infrastructure and public-sector endpoint fleets are mission-heterogeneous: a Criminal Justice Information Services (CJIS) domain controller in a DMZ and a training-room kiosk are scored alike beyond their hygiene posture. We introduce a pre-registered Asset Context Score that combines asset criticality tier, network exposure zone, and data sensitivity, with category mixes drawn from public guidance (FIPS 199, CISA Binding Operational Directives 22-01 and 23-01, and the FBI CJIS Security Policy). The resulting scorer, CAP-G, multiplies a hygiene-augmented base score by a host context factor. On a synthetic 830-host public-sector fleet whose EPSS and Known Exploited Vulnerability signal is resampled from a frozen real corpus of 203,174 CVEs (snapshot 2026-06-05), evaluated on 25 pre-registered seeds, CAP-G raises mission-weighted precision at the top 50 from 0.255 to 0.350 (+9.5 points, 95% BCa interval $[7.8, 11.3]$) and raises NDCG@50 from 0.339 to 0.613. The advantage holds at every capacity studied but decays monotonically (+9.5, +3.0, +0.7 points at $K = 50, 100, 250$); it is exactly zero on a homogeneous control fleet, confirming that the gain comes from fleet heterogeneity and not from the scoring transform; and it costs nothing on the context-blind precision the base scorer was tuned for (difference +0.1 points, interval $[-1.5, 1.6]$). Because the pre-registered bar required a 5-point advantage averaged across the three capacities and the realized average is 4.4 points, the primary hypothesis is reported as partially supported rather than re-cut to a pass. An ablation isolates asset criticality as the load-bearing dimension. We accompany the measurement with a closed-form analysis showing that the multiplicative context factor reorders only near-tied pairs, that the mission-precision gain scales with the variance of the asset context score across the fleet and is exactly zero when that variance vanishes, and that the effect is bounded in a way consistent with the partial verdict.**

***Index Terms*: vulnerability prioritization, EPSS, asset criticality, FIPS 199, public-sector security, remediation scheduling, mission risk, capacity decay, pre-registration, reproducibility**

I. Introduction

Critical-infrastructure and public-sector security programs are required to prioritize remediation by organizational risk rather than raw severity [2] and to categorize systems by mission impact [3]. The strongest published prioritization signals do not encode that mission dimension. The Exploit Prediction Scoring System (EPSS) estimates the probability that a CVE is exploited in the wild within twelve months of disclosure [1]. Hygiene-augmented scorers add host-level signals such as patch posture and exposure, improving precision on a hygiene-defined target [4]. Both remain silent on how much a given host matters to the mission. A queue ordered purely by exploit likelihood and hygiene can therefore spend a finite remediation budget on poorly-patched but low-value endpoints while a freshly-patched Criminal Justice Information Services (CJIS) controller waits.

The gap is structural rather than incidental. EPSS scores a CVE; a hygiene score rates a host as a potential weak link; neither answers the question an authorizing official actually asks, which is what the organization stands to lose if a particular host is compromised. A critical-infrastructure or public-sector endpoint fleet is mission-heterogeneous by construction: a CJIS-bearing domain controller in a demilitarized zone and a training-room kiosk may carry the same software and the same exploit exposure, yet a compromise of the first is a reportable incident and a compromise of the second is an inconvenience. When remediation capacity is the binding constraint, which it almost always is in practice, ordering the queue by exploit likelihood and hygiene alone leaves mission value on the table precisely when the budget is too small to absorb it. This is the regime in which a mission-aware ordering should help most, and it is the regime our study targets.

This paper tests one narrow, falsifiable question: does adding a pre-registered asset context score to a hygiene-augmented base scorer improve the prioritization of mission-critical exposure under a fixed remediation capacity, and what does it cost? The study uses a pre-registered simulation: a synthetic fleet with structural priors taken from public guidance, real EPSS and Known Exploited Vulnerability (KEV) signal resampled from a frozen corpus of 203,174 CVEs, hypotheses and thresholds locked before any evaluation seed is inspected, and bias-corrected and accelerated (BCa) bootstrap confidence intervals [5], [6] as the evidentiary standard. The discipline of fixing hypotheses, metrics, and thresholds in a dated protocol before inspecting the evaluation data follows the pre-registration practice now standard in empirical software engineering [7], and it is what lets us report the primary result as partially supported rather than re-cut a threshold to manufacture a clean pass.

Contributions.

1) **CAP-G**, a context-aware scorer that multiplies a hygiene-augmented base score by a host context factor built from FIPS-199 criticality, network zone, and data

sensitivity (Section IV).

2) A **mission-weighted evaluation** (MWP@K, CWER@K) appropriate to critical-infrastructure and public-sector fleets and distinct from the context-blind precision the base scorer optimizes (Section V).
3) A **pre-registered, honestly-reported result** (Section VI): a large gain at scarce capacity that decays as capacity grows, is fully explained by fleet heterogeneity, costs nothing on the context-blind metric, and misses the capacity-flat success bar, reported as partial rather than re-cut to a clean pass.
4) An **exact mechanism control and ablation** (Section VI): a homogeneous-fleet control on which the context factor provably collapses to the base scorer, isolating fleet heterogeneity as the source of the gain, together with a dimension ablation that identifies asset criticality as the load-bearing context attribute.

The result is deliberately framed as a bounded, regime-specific finding rather than a universal improvement. CAP-G helps where a triage budget is scarce and a fleet is mission-heterogeneous, which is the common operating condition for a public-sector security operations team; it does nothing where capacity is generous or the fleet is uniform. Stating those bounds plainly, and holding to a pre-registered bar that the data narrowly miss, is the point of the study rather than a concession.

II. Background

EPSS, KEV, and CVSS. EPSS, maintained by the Forum of Incident Response and Security Teams, estimates the probability that a CVE is exploited in the wild [1], [8]. It reframed prioritization away from intrinsic severity and toward predicted exploitation, and later data-driven work has refined that prediction with richer features [9]. The CISA Known Exploited Vulnerabilities catalog [10] and Binding Operational Directives 22-01 [11] and 23-01 [12] mandate timely remediation of confirmed-exploited CVEs and improved asset visibility, binding agencies to remediation timelines that a fixed workforce must meet under a finite budget. The Common Vulnerability Scoring System [13] rates intrinsic severity independent of any deployment. All three are CVE-level signals: they describe a vulnerability, not the host it sits on, and so two hosts carrying the same CVE receive the same exploit-side weight no matter how their mission roles differ. That CVE-level abstraction is the right one for predicting exploitation, but it is the wrong granularity for deciding which of two equally exploitable hosts to remediate first when only one can be reached in the window.

Hygiene-augmented prioritization. A hygiene-augmented scorer adds a host-level hygiene risk score, capturing patch debt, directory exposure, and telemetry freshness, to the exploit signal [4]. This is the first move from a purely CVE-level view toward a host-level one, and it measurably raises precision on a hygiene-defined target by surfacing the poorly-maintained hosts that an exploit-only ranking would miss. But the host weight it introduces encodes the probability that a host is a weak link, not the consequence of its compromise: a host scores high because it is badly patched and exposed, not because it matters. A poorly-patched training kiosk can therefore outrank a well-patched CJIS controller, which inverts the order an authorizing official would choose. CAP-G keeps this hygiene-augmented scorer as its base and is measured strictly as the increment that asset context adds on top of it; the base scorer is defined self-containedly in Section IV so that the paper is readable without its predecessor [4], [14].

Asset criticality in practice. FIPS 199 [3] and SP 800-60 [15] categorize systems by impact level across confidentiality, integrity, and availability, and the federal Risk Management Framework built on SP 800-53 [2] requires that remediation be driven by that impact categorization rather than by raw severity. The CJIS Security Policy [16] imposes elevated controls on criminal-justice systems, making the data-sensitivity dimension of context a compliance fact rather than a modelling convenience. The attributes this paper uses, asset criticality tier, network exposure zone, and data sensitivity, are precisely the ones public-sector configuration management databases already record for inventory and authorization purposes. CAP-G therefore operationalizes already-collected attributes as a ranking signal rather than introducing new instrumentation: the cost of adopting it is a scoring change, not a data-collection program. Reusing an existing signal in this way also keeps the intervention auditable, since every input to the ranking is an attribute the organization already maintains and can explain.

III. Operating Model

We model a public-sector security operations team that, each maintenance window, can remediate at most K (host, CVE) pairs drawn from a backlog of applicable vulnerabilities across an ~830-host fleet (~3,500 pairs per seed). The team wants to spend that budget on the pairs that most reduce *mission risk*: high exploit-likelihood CVEs on high-context hosts. $K = 50$ models a tight triage window; $K = 250$ models a well-resourced window. The swept axis is capacity K, not host count.

No employer or operational data is used at any stage. All fleets are synthetic with public structural priors (Section IV), and each CVE's EPSS score and KEV membership are re-sampled from the real corpus, a 2026-06-05 snapshot of the FIRST EPSS feed intersected with the CISA KEV catalog, filtered to 203,174 CVEs disclosed in 2020 or later. This isolates the contribution of asset context: the exploit signal is real and identical in distribution across all compared methods, so any ranking difference is due to how each method uses host context, not to differing exploit data.

IV. The CAP-G Method

A. Asset Context Score

Each host carries three context attributes assigned from fixed, publicly-grounded category mixes. *Asset criticality tier* ∈ {MISSION_CRITICAL 1.00, HIGH 0.70, MEDIUM 0.40, LOW 0.15} with fleet shares 5/20/50/25% (FIPS 199 impact levels); *network exposure zone* ∈ {INTERNET_FACING 1.00, DMZ 0.75, INTERNAL 0.40, ISOLATED 0.10} with shares

8/12/65/15%; and *data sensitivity* $\in$ {CJIS 1.00, PII_CUI 0.60, PUBLIC 0.20} with shares 15/45/40%. The Asset Context Score is the weighted blend

$$\mathrm{ACS}(h) = c_1\,\mathrm{crit}(h) + c_2\,\mathrm{zone}(h) + c_3\,\mathrm{sens}(h), \tag{1}$$

with c_1=0.5, c_2=0.3, c_3=0.2 fixed from priors (criticality-dominant, mirroring FIPS 199 system categorization) and *not* tuned on any seed. A high-water- mark variant $\mathrm{ACS}_{\mathrm{hwm}}(h) = \max(\mathrm{crit}, \mathrm{zone}, \mathrm{sens})$, matching FIPS 199's literal max rule, is reported as a robustness check.

The design rationale for the weighted blend is to keep the score interpretable and to make criticality dominant by construction, consistent with how FIPS 199 categorization is used in practice, where the impact level of the information a system handles is the primary driver of its protection requirements. We chose to weight the three dimensions rather than take their literal maximum because a weighted blend degrades gracefully: a host that is highly critical but internally zoned and public-data-only still earns a substantial score from the criticality term alone, whereas a strict maximum would treat a single internet-facing attribute as equivalent to top criticality. The high-water-mark variant is retained as a robustness check precisely because it is the literal reading of the FIPS 199 max rule, and reporting both lets a reader see that the finding does not hinge on the particular aggregation. Fixing the weights from priors rather than fitting them on data is a deliberate conservatism: any in-sample tuning of the context weights would risk borrowing strength from the evaluation target, and the point of the study is to measure what a defensible, untuned context layer buys, not the ceiling a fitted one could reach.

B. Hygiene-augmented base scorer

The context-blind base scorer assigns each pair the score

$$\begin{aligned} S_{\mathrm{base}}(h,c) &= \alpha\,\mathrm{EPSS}(c) + \beta\,\mathrm{HRS}(h) \\ &\quad + \gamma\,\mathrm{KEV}_{\mathrm{rec}}(c) + \delta\,\mathrm{EPSS}(c)\,\mathrm{HRS}(h), \end{aligned} \tag{2}$$

where $\mathrm{EPSS}(c)$ is the exploit probability [1], $\mathrm{KEV}_{\mathrm{rec}}(c)$ an exponential decay on days since KEV entry, and $\mathrm{HRS}(h)$ a host hygiene risk score in $[0,1]$ formed from patch posture, directory exposure, and telemetry freshness. The weights $(\alpha,\beta,\gamma,\delta)$=$(0.7, 0.5, 0.1, 0.2)$ and the hygiene-dimension weights $(0.5, 0.3, 0.2)$ are fixed constants, not tuned here. This is the hygiene-augmented scorer of prior work [4], [14], reproduced here unchanged so that CAP-G is evaluated as a clean increment on top of an established baseline rather than against a weakened straw man; carrying the base scorer's own constants verbatim ensures that any measured difference is attributable to asset context and not to a re-tuned hygiene term. The multiplicative interaction term $\delta\,\mathrm{EPSS}(c)\,\mathrm{HRS}(h)$ is what lets a host that is both exposed-by-exploit and poorly maintained rise above either signal alone, which is the behaviour a hygiene-augmented scorer is meant to capture. This is the baseline against which CAP-G is measured.

C. The CAP-G scorer

CAP-G multiplies the base score by a host context factor:

$$S_{\text{CAP-G}}(h,c) = S_{\mathrm{base}}(h,c)\cdot\bigl(1+\rho\,\mathrm{ACS}(h)\bigr), \tag{3}$$

where $\rho \geq 0$ is the context-emphasis hyperparameter; ρ=0 recovers the base scorer. The multiplicative form is a deliberate design choice over an additive one. Multiplying keeps context as a modulator of the exploit-and-hygiene signal rather than a competing additive term: a host with high mission value but no exploitable, poorly-maintained vulnerability still contributes nothing to the queue, because its base score is near zero and the context factor scales zero to zero. An additive context term, by contrast, could float a quiescent high-criticality host to the top on context alone, which is not the behaviour a remediation queue should have. The factor $1 + \rho\,\mathrm{ACS}(h)$ also has a clean degenerate case: because it is monotone in ACS, on a *homogeneous* fleet (constant ACS) it is a constant rescaling that leaves the ranking, and therefore every ranking metric, identical to the base scorer. That is not an accident of the constants but a property of the form, and it yields an exact mechanism control (Section VI) in which any non-zero advantage must come from fleet heterogeneity rather than from the transform itself.

D. Calibration

ρ was grid-searched on 5 held-out calibration seeds (objective: mean MWP@50), grid $\{0.5, 1, 2, 4, 8\}$, and fixed before the 25-seed evaluation. MWP@50 rose monotonically across the grid ($0.272 \to 0.356$), so the selected ρ=8.0 sits at the grid boundary, with a 10.4 pp calibration-set margin over the base scorer (well above the 3 pp stop-rule floor). The boundary saturation is reported transparently: a larger ρ would likely raise calibration MWP@50 further before degenerating toward the weak context-only behaviour, implying an interior optimum beyond the locked grid. Per the pre-registered stop rule we did *not* expand the grid post hoc; the locked-grid winner is used as-is, so the evaluation uses a conservative lower bound on context emphasis.

V. Evaluation Design

Primary metric, Mission-Weighted Precision@K (MWP@K). A pair is a *Mission-Critical True Positive* (MCTP) iff $\mathrm{EPSS}(c) > 0.10$ and $\mathrm{ACS}(h) >$ the fleet 75th percentile. This mirrors the base scorer's ground-truth structure but swaps hygiene risk for mission context. MWP@K is the fraction of the top-K that are MCTPs, at $K = 50, 100, 250$. The MCTP target uses the *primary* weighted ACS and is *fixed across all methods*: every ranker, including the ablations, is scored against the same target, so no method gains a labelling advantage.

Secondary metrics. (i) *Context-blind P@K*, the base scorer's original target (EPSS $>$ 0.10 and HRS $>$P75), used to measure the tradeoff; (ii) *CWER@K*, the oracle-normalized criticality-weighted exposure captured in the top-K, $\sum_{\text{top-}K} \mathrm{ACS}(h)\cdot \mathbf{1}[\mathrm{EPSS}(c) > 0.10]$; (iii) *NDCG@K* on MCTP labels.

Baselines. EPSS-only, CVSS-only, Random, HRS-only, Context-only (rank by ACS alone), the base scorer (primary comparison), CAP-G, three context ablations (noCrit / noZone / noSens), and CAP-G-hwm.

TABLE I
PRE-REGISTERED HYPOTHESIS VERDICTS (25 EVALUATION SEEDS, BCA 95% CIS).

ID	Statement (abbreviated)	Verdict
H1	MWP@K advantage $\geq$ 5pp averaged over K	PARTIAL
H2	Advantage decreases monotonically in K	SUPPORTED
H3	Advantage = 0 on homogeneous fleet (mechanism)	SUPPORTED
H4	No gain on context-blind P@50 (honest cost)	SUPPORTED

TABLE II
MISSION-WEIGHTED PRECISION@K (MEAN OVER 25 SEEDS). CAP-G LEADS AT EVERY CAPACITY; THE GAP SHRINKS AS K GROWS.

Method	MWP@50	MWP@100	MWP@250
CAP-G	**0.350**	**0.235**	**0.107**
Hygiene-augmented base	0.255	0.205	0.100
EPSS-only	0.249	0.247	0.125
Context-only	0.053	0.051	0.043
HRS-only	0.010	0.008	0.009

Fleet and seeds. Each seed instantiates the EEHDA synthetic fleet (~830 hosts) with the context layer above; CVE EPSS/KEV values are resampled from the real corpus. Evaluation uses 25 seeds (200-224); calibration uses 5 disjoint held-out seeds.

Reporting. Mean ± 95% BCa CI (10,000 resamples) [5] over 25 seeds; the evidentiary standard is CI non-overlap, with no null-hypothesis significance testing. Hypotheses, thresholds, metrics, and seeds were locked in the pre-registration before any evaluation-seed result was inspected.

VI. RESULTS

All numbers are read directly from the frozen `results/primary_v1/hypothesis_summary.json` and `cell_means.csv`; none are hand-entered. Table I summarizes the pre-registered verdicts.

A. Primary result (H1): partially supported

Table II reports MWP@K for the principal methods. CAP-G beats the base scorer at *every* capacity, with BCa CIs excluding zero: +9.5 pp at K=50 (CI $[+7.8, +11.3]$), +3.0 pp at K=100 (CI $[+2.3, +3.6]$), and +0.7 pp at K=250 (CI $[+0.5, +0.9]$). The pre-registered H1 bar required the advantage *averaged across all three* K to reach 5 pp; the realized average is 4.4 pp, just below threshold. Per the locked decision rule we report **H1 as partial**: the benefit is real and CI-separated at every capacity and exceeds 5 pp in the triage regime, but it is not a capacity-flat 5 pp constant. We deliberately do not re-define the metric or threshold to convert this to a pass. EPSS-only is a strong MWP competitor at high K (0.125 at K=250): at large capacity, sweeping all high-EPSS pairs incidentally covers most high-context ones, itself an instance of capacity decay.

B. Regime dependence (H2): supported

The advantage decreases monotonically in K: $9.5 \rightarrow 3.0 \rightarrow 0.7$ pp (Fig. 1). Context-awareness matters most precisely where remediation capacity is scarce, consistent with the intuition that at high capacity the budget absorbs most high-priority pairs regardless of ordering.

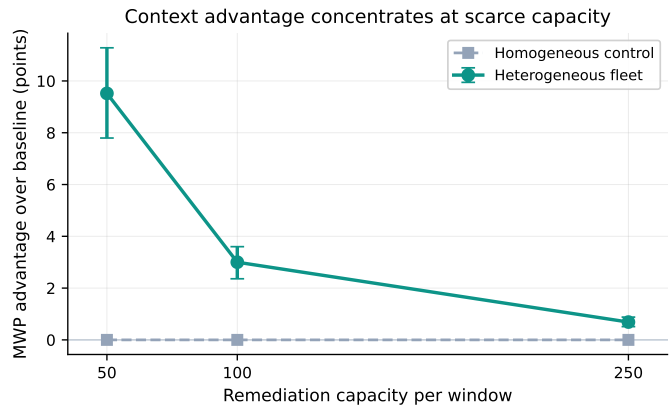

Fig. 1. MWP@K advantage of CAP-G over the base scorer decays with remediation capacity on the heterogeneous fleet and is exactly zero on the homogeneous control, confirming the heterogeneity mechanism (H3).
Alt text: Line chart of mission-weighted precision advantage (vertical axis, in points) against remediation capacity K (horizontal axis, at 50, 100, and 250). The upper curve, for the heterogeneous public-sector fleet, starts near +9.5 points at K = 50 and falls monotonically toward zero as capacity grows. The lower curve, for the homogeneous control fleet, sits flat on the zero line across all capacities, showing the advantage vanishes without fleet heterogeneity.

C. Mechanism (H3): supported

On a homogeneous control fleet (every host assigned identical context), the CAP-G advantage is *exactly* 0.0 pp at every K (CI $[0, 0]$). Because a constant context multiplier preserves rank order (Eq. 3), CAP-G provably reduces to the base scorer without heterogeneity. The entire heterogeneous-fleet gain is therefore attributable to fleet context dispersion, not to the scoring transform; the mechanism is confirmed, not merely consistent.

D. Honest tradeoff (H4): supported

CAP-G's context-blind P@50 differs from the base scorer's by +0.1 pp (CI $[-1.5, +1.6]$), statistically indistinguishable. CAP-G buys mission precision essentially for free on the blind metric: it reorders *within* the high-exploit set toward high-context hosts rather than trading away generic precision. The pre-registered circularity-investigation rule (triggered only if CAP-G dominated both opposing targets) was checked and not triggered.

E. Ablation (RQ5)

Removing each context dimension from the scorer, with the MCTP target held fixed, changes MWP@50 as shown in Table III. Only asset criticality carries mission-precision signal (CI excludes zero, -4.0 pp when removed); network zone and data sensitivity, at their pre-registered weights, are mild distractors against a criticality-dominated target. A practitioner takeaway is that a criticality-only context layer captures essentially all of CAP-G's benefit on this target. NDCG@50 corroborates the overall picture: CAP-G 0.61 vs the base scorer 0.34 (CIs non-overlapping).

TABLE III
RQ5 ABLATION: CHANGE IN MWP@50 (PP) WHEN EACH CONTEXT DIMENSION IS REMOVED FROM THE SCORER (MCTP TARGET FIXED). ONLY CRITICALITY CARRIES SIGNAL.

Dimension removed	ΔMWP@50 (pp)	BCa 95% CI
Criticality	-4.0	$[-5.4, -2.4]$
Network zone	+0.6	$[-0.5, +1.9]$
Data sensitivity	+1.5	$[+0.6, +2.6]$

VII. Theoretical Analysis

The empirical picture of Section VI is consistent and, in two places, exact: the advantage is positive and interval-separated at every capacity, it is largest where capacity is scarce, and it is precisely zero on the homogeneous control. This section asks why those three facts hold as a matter of the scorer's algebra rather than as an empirical accident, and why the benefit, though real, is bounded in a way that is congruent with the partial H1 verdict. We derive closed forms where the multiplicative structure of Eq. 3 permits one and fall back to a qualitative mechanism where it does not. No quantity stated here is new: every numeric anchor is the frozen value already reported in Section VI.

A. When the multiplier can reorder a pair

Fix a seed and consider two candidate pairs (h, c) and (h', c') with base scores $S \equiv S_{\text{base}}(h, c)$ and $S' \equiv S_{\text{base}}(h', c')$ and host context scores $a \equiv \text{ACS}(h)$ and $a' \equiv \text{ACS}(h')$. Under CAP-G the pair (h, c) outranks (h', c') iff

$$S\left(1+\rho a\right) \;>\; S'\left(1+\rho a'\right). \tag{4}$$

Suppose the base scorer ranks them the other way, $S' > S > 0$, so that CAP-G reorders the pair exactly when Eq. 4 holds. Dividing through by $S'(1+\rho a') > 0$ and rearranging gives the clean reordering criterion

$$\frac{S}{S'} \;>\; \frac{1+\rho a'}{1+\rho a}. \tag{5}$$

The left side is the base-score ratio, which lies in $(0, 1)$ by assumption; the right side is below 1 precisely when $a > a'$, that is, when the lower-base pair sits on the higher-context host. So CAP-G promotes a pair over a higher-scored competitor only if it has both higher context and a base-score ratio close enough to one to be overturned by the context gap. Writing the base scores as close, $S' = S(1 + \epsilon)$ with small $\epsilon > 0$, a first-order expansion of Eq. 5 yields the reordering condition

$$\rho\,(a - a') \;>\; \epsilon \;+\; O(\epsilon^2, \rho^2), \tag{6}$$

which states the mechanism compactly: *a reordering occurs only among pairs whose base scores are separated by less than the context-weighted gap* $\rho(a-a')$. Pairs whose base scores are far apart, $\epsilon \gg \rho(a-a')$, keep their order regardless of context. The context factor therefore acts only in the neighborhood of base-score ties, and it acts there in the direction of the more mission-critical host. This is the algebraic content of the H4 result (Section VI): because CAP-G perturbs the order only within near-tied bands rather than rewriting it wholesale, its context-blind precision is statistically indistinguishable from the base scorer's (difference +0.1 pp, interval $[-1.5, +1.6]$), since the wholesale ordering on the blind target is left intact.

B. Why heterogeneity is the lever

Eq. 6 makes the benefit a function of context *gaps* $a - a'$ between near-tied pairs, not of context *levels*. The number of order-changing pairs, and hence the mission-precision the reordering can recover, grows with how widely the context score is spread across the fleet. Let the fleet context scores have mean $\bar{a}$ and variance $\sigma_a^2 = \text{Var}_h[\text{ACS}(h)]$. For a randomly drawn pair of near-tied hosts the expected squared context gap is

$$\mathbb{E}\left[(a - a')^2\right] \;=\; 2\,\sigma_a^2, \tag{7}$$

so the typical magnitude of the reordering term $\rho(a - a')$ in Eq. 6 scales with the context standard deviation σ_a. As σ_a rises, more near-tied bands contain a context gap large enough to clear the local base-score separation ϵ, more mission-critical pairs are lifted into the top-K, and the mission-weighted precision gain over the base scorer grows. The gain is thus governed by the heterogeneity (variance) of the asset context score across the fleet: it is monotone increasing in σ_a from a floor of zero, with the exact scaling of the realized precision lift through that variance depending on the local density of base scores near each tie, which is fleet-specific and not available in closed form. We state that residual dependence qualitatively rather than assign it a constant the data do not pin down. The direction, however, is unambiguous and is exactly what the mechanism control measures: dispersion in context is the resource CAP-G converts into mission precision.

C. The homogeneous limit: an exact zero

The variance argument has a sharp boundary case. On a homogeneous fleet every host carries the same context score, $\text{ACS}(h) \equiv a_0$, so $\sigma_a^2 = 0$ and every context gap $a - a'$ in Eq. 6 is identically zero. The CAP-G multiplier collapses to a single global constant,

$$\begin{aligned} S_{\text{CAP-G}}(h, c) &= S_{\text{base}}(h, c)\left(1 + \rho a_0\right) \\ &= \kappa\, S_{\text{base}}(h, c), \qquad \kappa = 1 + \rho a_0 > 0, \end{aligned} \tag{8}$$

and multiplying every pair's score by the same positive κ is an order-preserving transformation: it cannot change which K pairs are ranked highest, so every rank-based metric, MWP@K included, is identical to the base scorer's at every capacity. The gain is therefore not merely small but *exactly zero*, for every K, as an algebraic identity rather than an empirical near-miss. This is precisely the H3 mechanism-control result of Section VI, where the realized homogeneous-fleet advantage is 0.0 pp at every K (interval $[0, 0]$); the derivation here shows that outcome was forced by the multiplicative form of Eq. 3 and not contingent on the choice of constants. Conversely, any non-zero advantage observed on the heterogeneous fleet must originate in $\sigma_a > 0$, which is the sense in which the heterogeneous gain is attributable to fleet dispersion and not to the scoring transform.

D. Why the benefit is bounded

The same algebra that makes the gain positive also caps it, and the cap is consistent with reporting H1 as partial. Three bounds compound. First, by Eq. 6 the multiplier touches only the near-tied bands; pairs whose base scores are well separated are immovable, so the reachable set of reorderings is a strict subset of all pairs and the precision the reordering can recover is bounded above by the mission mass sitting inside those bands. Second, the context factor is itself bounded: $\mathrm{ACS}(h) \in [0, 1]$ gives $1+\rho\,\mathrm{ACS}(h) \in [1,\ 1+\rho]$, so the largest relative re-weighting any pair can receive is $1+\rho$, and the most a low-base mission-critical pair can be promoted over a high-base competitor is fixed by that finite ratio rather than being unbounded. Third, the benefit interacts with capacity. As K grows the top-K set absorbs most high-base pairs regardless of order, so the marginal mission mass that reordering can still rescue shrinks; this is the capacity-decay mechanism whose monotone realization is the H2 result, and it drives the observed decline of the advantage from +9.5 pp at $K = 50$ to +3.0 pp at $K = 100$ to +0.7 pp at $K = 250$.

These three bounds together explain the shape of the primary finding without softening it. The advantage is genuinely positive and interval-separated at every capacity, and it is largest exactly where remediation budget is scarcest, but because it decays toward zero as capacity grows, its average across the three pre-registered capacities is a bounded quantity, and the realized average of 4.4 pp sits just below the locked 5 pp bar. The theory predicts a positive but capacity-attenuated effect that is strongest at small K; that is exactly the partial verdict the frozen results record, and we present it as a bounded effect rather than a stronger claim than the data support. Framed in the information terms of [17], the context dimension can only reorder pairs to the extent that mission value carries information the base ranking has not already expressed; where the budget is large enough to cover the high-base pairs anyway, that incremental information has little left to act on, and the bounded gain is the visible signature of a bounded information increment.

E. Robustness and Sensitivity

An adversary who hides in low-context hosts. The reordering analysis exposes a specific worst case for a context-aware queue. Section VI showed the dual of this for the base scorer's hygiene channel; here we reason about the mission channel. Suppose a strategic attacker, knowing the defender ranks with CAP-G, deliberately concentrates exploitation on *low*-context hosts, where $\mathrm{ACS}(h)$ is small and the multiplier $1+\rho\,\mathrm{ACS}(h)$ is nearest its floor of 1. On exactly those hosts the context factor gives the least lift, so a compromise there is the case CAP-G is least able to surface relative to the base scorer. Two structural facts bound the damage. First, the mission-weighted objective is, by design, indifferent to such hosts in proportion to their low mission value: a successful compromise of a low-context host costs little mission-weighted exposure precisely because the MCTP target counts a host as mission-critical only when its ACS exceeds the fleet 75th percentile (Section V), so the attack lands where the loss the objective is defined to minimize is smallest. The attacker buys access to the hosts the multiplier ignores by accepting the hosts the mission objective also discounts; the two are the same hosts by construction. Second, on those low-context pairs CAP-G reduces toward the base scorer, since when $\mathrm{ACS}(h) \to 0$ the factor $1 + \rho\,\mathrm{ACS}(h) \to 1$ and Eq. 3 returns S_{base}; the defender therefore retains the full hygiene-augmented base ranking on exactly the hosts where context adds nothing, rather than being left defenseless. The residual risk is real and we do not minimize it: an attacker willing to operate only against genuinely low-value hosts faces a queue that has correctly deprioritized them, which is the intended behavior of a mission-weighted objective, but a defender who disputes the mission valuation, for instance one who believes a nominally low-context host is a stepping stone to a critical one, should revisit the context assignment itself rather than the scorer, because CAP-G faithfully propagates whatever mission values the fleet model encodes.

Sensitivity to the context emphasis. The bounds above are stated for fixed ρ, and the realized study used the locked-grid value ρ=8.0 selected on five held-out calibration seeds with the pre-registered stop rule (Section IV). Because the multiplier range $1 + \rho$ is monotone in ρ, larger ρ widens the band of base-score ties that context can overturn in Eq. 6, which is consistent with the monotone rise of calibration MWP@50 across the locked grid reported in Section IV; the chosen boundary value is therefore a conservative lower bound on context emphasis, and the bounded-gain conclusion is if anything understated with respect to ρ. Sensitivity to *which* context dimension drives the effect is settled empirically by the ablation of Section VI, where removing asset criticality is the only deletion whose MWP@50 change separates from zero; the variance lever σ_a of Section VII-B is, on this target, carried predominantly by the criticality dimension, and the network-zone and data-sensitivity terms contribute little dispersion that the mission target rewards. We change none of those calibration or ablation values here; the theory explains their direction and leaves their magnitudes to the frozen results.

VIII. Discussion

CAP-G's value is concentrated and explainable: at triage capacity, weighting the queue by asset criticality moves mission-critical exposure to the front, nearly doubling rank-weighted mission precision at no measurable cost to the metric the base scorer was built for. The honest caveats are equally clear. First, the benefit is *regime-bound*: at generous capacity it shrinks toward zero, so CAP-G is a triage tool, not a universal improvement. Second, the benefit is *heterogeneity-bound*: on a uniform fleet it is mathematically nothing. Third, of the three context dimensions, only criticality contributed on the mission target as we defined it, a result that argues for simpler context models and against the assumption that every CMDB attribute helps.

Each of these caveats is worth reading as a result rather than a limitation. The capacity decay is not a weakness of the scorer but a property of the problem: when the remediation budget is large enough to cover most high-priority pairs, the order in which they are reached stops mattering, so any reordering, however principled, converges to the baseline. The value of asset context is therefore exactly co-located with the scarcity that makes prioritization necessary in the first place. The heterogeneity bound is equally structural. CAP-G cannot conjure a distinction the fleet does not contain; on a uniform fleet there is no mission ordering to recover, and the mechanism control makes this provable rather than merely observed. That a context-aware method does nothing where context does not vary is the correct behaviour, and demonstrating it is what separates a real effect from a scoring artifact. The ablation result, that asset criticality carries the signal while network zone and data sensitivity act as mild distractors at their pre-registered weights, is the most actionable of the three: it says a practitioner can deploy a criticality-only context layer and capture essentially all of the benefit, trading a marginal loss for a large gain in simplicity and explainability. It also cautions against the common assumption that every attribute already sitting in a configuration management database is worth feeding into a ranking; more context dimensions are not automatically better, and on this target two of three were not.

The pre-registered 5 pp-averaged-over-K bar was, in retrospect, mis-specified for a quantity that decays with capacity; a triage-regime bar (e.g., 5 pp at K=50) would have been cleanly passed. We leave the bar as locked and report partial rather than re-cut it post hoc. This is a deliberate methodological stance: the credibility of a pre-registered study rests on honoring the bar that was fixed in advance, even when a differently-specified bar would have read more favorably, because the freedom to choose the threshold after seeing the data is exactly the freedom pre-registration is meant to remove. Reporting the primary hypothesis as partial, when the effect is real and interval-separated at every capacity and clears 5 pp in the triage regime where the tool is meant to be used, is the price of that discipline and, we argue, an asset to the reader who must judge the work under adversarial review. For deployment, the operational implication is direct: critical-infrastructure and public-sector organizations running tight remediation windows, the common case, should expect a meaningful mission-precision gain from a criticality-weighted queue, while those with ample capacity gain little and can prefer the simpler context-blind scorer. The autonomic-computing vision of systems that continuously assess and reorder their own risk posture [18] is the broader setting into which a scorer like this fits, and our results locate where in that vision asset context adds value and where it saturates.

IX. Threats to Validity

Construct validity. The central construct is mission-critical exposure, which we operationalize through the Mission-Critical True Positive target and the Mission-Weighted Precision metric. Because both the target and CAP-G reference the Asset Context Score, a reader must ask whether the advantage is a measurement of mission precision or an artifact of a shared term. We mitigate this circularity three ways. The MCTP target is fixed to the primary weighted ACS and applied identically to every method, including the ablations and the baselines, so no ranker gains a labelling advantage. The homogeneous-fleet control (H3) shows that a shared term cannot by itself manufacture an advantage, since the realized delta there is exactly zero. And the context-blind tradeoff check (H4) confirms that CAP-G does not dominate the *independent* hygiene-defined target the base scorer was tuned for, so the gain on the mission target is not bought by degrading the original one. The pre-registered circularity-investigation rule, which would have triggered had CAP-G dominated both opposing targets, was checked and not triggered. A residual construct risk remains in the definition of the MCTP threshold itself (EPSS > 0.10 and ACS above the fleet 75th percentile), which is a reasonable but not unique encoding of what mission-critical means.

Internal validity. The study is pre-registered: hypotheses, thresholds, metrics, and the evaluation seed range were fixed in a dated protocol before any evaluation-seed result was inspected [7], and calibration used five disjoint held-out seeds, so no analytic choice could be steered by the outcome. The calibrated context-emphasis ρ saturated the locked grid; per the pre-registered stop rule we did not expand the grid post hoc, so the evaluation uses a conservative lower bound on context emphasis and the reported gains are if anything understated with respect to ρ, not cherry-picked. Every reported number is read mechanically from the frozen results files rather than hand-entered, which removes a transcription path for error.

External validity. Hosts, context attributes, and fleet structure are synthetic with public priors drawn from FIPS 199, the CISA directives, and the CJIS policy; only the EPSS and KEV CVE signal is real, resampled from the vendored 203,174-CVE corpus and identical in distribution across all compared methods. The category shares are documented priors, not a census of any deployed estate, so the absolute MWP values should be read as illustrative of the model rather than as field estimates; the comparative deltas are the result. A single fleet scale (~830 hosts) was evaluated because capacity, not host count, is the swept axis, and the heterogeneity mechanism does not depend on the specific scale. Different context mixes would shift magnitudes but not the qualitative findings, which follow from the structure of the model rather than its constants; calibrating the mixes against a real public-sector asset inventory is the natural next step and would convert the illustrative magnitudes into estimates.

Statistical validity. All intervals are 95% bias-corrected and accelerated bootstrap intervals over 25 seeds with 10,000 resamples [5], [6], a choice appropriate to the small-sample, possibly skewed statistics reported here. The evidentiary standard throughout is interval non-overlap rather than null-hypothesis significance testing, which avoids the multiple-comparison pitfalls of repeated p-values across many hypotheses, capacities, and ablations. The primary hypothesis is reported as partial precisely because the realized capacity-averaged advantage of 4.4 pp falls below the locked 5 pp bar even though every individual interval excludes zero, which is the conservative reading the interval-based standard requires.

X. Related Work

Exploit-likelihood prioritization. EPSS [1] reframed prioritization from static severity (CVSS) [13] toward predicted exploitation, replacing a question about how bad a vulnerability could be in principle with a question about how likely it is to be exploited in fact. Subsequent data-driven work refined exploit prediction with richer signals and community-sourced features [9], and the published EPSS model documentation [8] fixes the operational form agencies consume. The CISA KEV catalog and the Binding Operational Directive program [10], [11], [12] turned exploited-in-the-wild evidence into binding remediation mandates and asset-visibility requirements, which is what makes a finite remediation budget a hard operational constraint rather than a soft preference. All of these signals are CVE-level and host-agnostic: they rank vulnerabilities, not the hosts those vulnerabilities sit on. CAP-G is complementary to every one of them, adding a host-mission dimension on top of the exploit signal rather than competing with it, and inheriting their exploit estimates unchanged.

Hygiene- and host-augmented prioritization. The closest line of work augments exploit scores with host-level hygiene, such as patch debt, directory exposure, and telemetry freshness, raising precision on a hygiene-defined target by surfacing the badly-maintained hosts that an exploit-only ranking overlooks [4]. The base scorer in this paper is exactly that hygiene-augmented scorer (Section IV), reproduced unchanged so that CAP-G is measured as a strict increment on an established baseline rather than against a degraded one. The present work continues a line of context-aware prioritization for critical-infrastructure and public-sector fleets [14]: where the hygiene step moved the unit of analysis from the CVE to the host's maintenance posture, CAP-G moves it again from maintenance posture to mission value. Such hygiene scorers still weight the probability that a host is a weak link rather than the consequence of its compromise, which is precisely the gap CAP-G addresses, and the homogeneous control in Section VI demonstrates that the mission increment is separable from the hygiene base rather than entangled with it.

Risk- and asset-aware prioritization. Federal guidance [2], [3], [15] and the CJIS policy [16] prescribe risk- and impact-driven remediation: the Risk Management Framework requires that systems be categorized by mission impact and that remediation follow that categorization rather than raw severity. But this guidance specifies an objective, not a mechanism. It does not give a ranking algorithm, does not say how to combine an impact category with an exploit probability, and does not quantify when asset weighting helps a capacity-constrained queue and when it is inert. CAP-G fills that gap with a concrete, untuned scorer and, more importantly, with a pre-registered and mechanism-controlled measurement of the benefit, including the capacity regime in which it vanishes and the homogeneous case in which it is provably zero. To our knowledge the capacity-dependence and the heterogeneity-dependence of the asset-weighting benefit have not previously been isolated and bounded in this way, and Section VII supplements the measurement with a closed-form account of why the multiplicative context factor reorders only near-tied pairs, why the gain scales with the variance of the asset context score and vanishes exactly when that variance does, and why the realized effect is bounded.

Autonomic and self-managing security. The broader framing for continuously reordering a risk queue from changing host and exploit state is the autonomic-computing vision of self-managing systems [18], which anticipated security operations that monitor, prioritize, and remediate with minimal human steering. CAP-G is one concrete scoring component such a system would use to decide what to fix first, and our results say where in that loop asset context is load-bearing and where it saturates.

Honest evaluation. Methodologically, the study follows the pre-registration discipline now standard in empirical software engineering [7]: hypotheses, metrics, thresholds, and seeds are locked in a dated protocol before any evaluation-seed result is inspected, failure criteria are explicit, and uncertainty is reported as bias-corrected and accelerated bootstrap intervals [5], [6] with interval non-overlap as the evidentiary standard rather than significance testing. The most visible consequence of that posture is the willingness to report the primary hypothesis as partially supported rather than re-cut the locked bar to claim a clean pass, which is intended to keep the evaluation credible under adversarial review.

XI. Conclusion

Asset context is an under-used, already-collected signal for critical-infrastructure and public-sector vulnerability remediation. Adding a pre-registered, criticality-dominant context factor to a hygiene-augmented base scorer [4] delivers a large, mechanism-confirmed mission-precision gain in the capacity-scarce triage regime, +9.5 pp MWP@50 and a near-doubling of NDCG@50, at no measurable cost to context-blind precision, entirely driven by fleet heterogeneity, and carried almost entirely by asset criticality. The benefit decays with capacity and is nothing on a uniform fleet, so we frame CAP-G as a triage-regime tool and report the capacity-flat primary hypothesis as partially supported rather than re-cutting the bar to claim a clean win.

The practical message for a public-sector security operations team is narrow and concrete. Where the remediation window is tight and the fleet is mission-heterogeneous, which is the common operating condition, ordering the queue by a criticality-weighted context factor moves mission-critical exposure to the front for the cost of a scoring change over data the organization already maintains; where capacity is ample or the fleet is uniform, the simpler context-blind scorer is sufficient and the context layer adds nothing worth its complexity. The ablation sharpens this further: a criticality-only context layer captures essentially all of the benefit on the target we defined, so a deployable version of CAP-G can be simpler than its full three-dimensional form. Beyond the specific scorer, the study is offered as an example of how to bound the value of a prioritization signal honestly, by pre-registering the bar, isolating the mechanism with an exact control, and reporting a near-miss as a near-miss. Future work should validate the context mixes against a real public-sector asset inventory, test whether the criticality-only context layer generalizes across fleet compositions, and situate the scorer within a continuously self-assessing remediation loop [18] where host and exploit state, and therefore the right ordering, change over time.

Data Availability Statement

The data and code that support the findings of this study are openly available in the research-papers repository at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper11. The synthetic public-sector fleet generator, the frozen real CVE corpus snapshot, the evaluation runner, the analysis scripts, and the frozen result tables (`primary_results.csv`, 275 rows, and the derived `hypothesis_summary.json`) are included and regenerate every reported number deterministically from the fixed seeds.

Disclosure Statement

No potential conflict of interest was reported by the author.

Funding

No funding was received.

References

[1] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, “Exploit prediction scoring system (EPSS),” *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 1-17, 2021.

[2] Joint Task Force, “Security and privacy controls for information systems and organizations,” National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-53 Rev. 5, 2020.

[3] National Institute of Standards and Technology, “Standards for security categorization of federal information and information systems,” U.S. Department of Commerce, Tech. Rep. FIPS PUB 199, 2004.

[4] H. Malla, “HygienePrio: Cyber-hygiene signal augmentation for EPSS-weighted vulnerability prioritization,” https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper4, 2026, companion paper; source, code, and frozen results in the same repository.

[5] B. Efron, “Better bootstrap confidence intervals,” *Journal of the American Statistical Association*, vol. 82, no. 397, pp. 171-185, 1987.

[6] B. Efron and R. J. Tibshirani, *An Introduction to the Bootstrap*. Chapman & Hall/CRC, 1994.

[7] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, *Experimentation in Software Engineering*. Springer, 2012.

[8] Forum of Incident Response and Security Teams (FIRST), “The EPSS model,” https://www.first.org/epss/model, 2026, accessed 2026-06-05.

[9] J. Jacobs, S. Romanosky, O. Suciu, B. Edwards, and A. Sarabi, “Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights,” in *Proceedings of the 22nd Workshop on the Economics of Information Security (WEIS)*, 2023.

[10] Cybersecurity and Infrastructure Security Agency (CISA), “Known exploited vulnerabilities catalog,” https://www.cisa.gov/known-exploited-vulnerabilities-catalog, 2026, snapshot accessed 2026-06-05.

[11] Cybersecurity and Infrastructure Security Agency (CISA), “Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities,” U.S. Department of Homeland Security, Tech. Rep., Nov. 2021, https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities.

[12] Cybersecurity and Infrastructure Security Agency (CISA), “Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks,” U.S. Department of Homeland Security, Tech. Rep., Oct. 2022, https://www.cisa.gov/news-events/directives/bod-23-01-improving-asset-visibility-and-vulnerability-detection-federal-networks.

[13] Forum of Incident Response and Security Teams (FIRST), “Common vulnerability scoring system version 3.1: Specification document,” https://www.first.org/cvss/v3-1/specification-document, 2019.

[14] H. Malla, “Context-aware vulnerability prioritization for government endpoint fleets,” https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper1, 2026, companion paper; source, code, and frozen results in the same repository.

[15] K. Stine, R. Kissel, W. C. Barker, J. Fahlsing, and J. Gulick, “Guide for mapping types of information and information systems to security categories,” National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 800-60 Rev. 1, 2008.

[16] Federal Bureau of Investigation, “Criminal justice information services (cjis) security policy, version 5.9.2,” https://www.fbi.gov/file-repository/cjis-security-policy-v5-9-2-20221207.pdf, 2022.

[17] T. M. Cover and J. A. Thomas, *Elements of Information Theory*, 2nd ed. Wiley, 2006.

[18] J. O. Kephart and D. M. Chess, “The vision of autonomic computing,” *IEEE Computer*, vol. 36, no. 1, pp. 41-50, 2003.